# Blind SSRF with Out-of-Band Detection

**Platform:** PortSwigger Web Security Academy
**Vulnerability:** Blind Server-Side Request Forgery (Blind SSRF)
**Testing Tool:** Burp Suite Collaborator
**Lab Status:** Practical Lab Write-up

## 1. Overview

Blind Server-Side Request Forgery (Blind SSRF) occurs when an application makes a server-side request to a destination influenced by user input, but the response from that destination is not returned to the user.

Because the response is not directly visible, identifying the vulnerability requires an alternative detection method. Out-of-band (OAST) testing can reveal server-side requests through interactions with an external system controlled by the tester.

## 2. Lab Objective

The objective is to identify blind SSRF by causing the vulnerable application to make an outbound request to a unique external address and observing the resulting interaction using Burp Suite Collaborator.

## 3. Tools Used

- **Burp Suite Proxy:** To intercept and modify application requests.
- **Burp Suite Collaborator:** To detect external DNS lookups or HTTP interactions initiated by the target server.
- **Browser:** To access the lab application and trigger the relevant functionality.

## 4. Methodology

1. Open the lab application and identify a feature that may cause the server to make outbound HTTP requests.
2. Intercept the relevant request in Burp Suite Proxy.
3. Inspect request parameters and headers for values that may influence server-side network activity.
4. Open Burp Suite Collaborator and generate a unique Collaborator address.
5. Insert the unique address into the suspected input location in the authorized lab request.

6. Forward the modified request to the application.
7. Check the Collaborator interaction log for DNS queries or HTTP requests associated with the unique address.
8. Correlate the observed interaction with the test request to determine whether the application initiated an outbound request.
9. Record the evidence and complete any additional verification required by the lab.

# 5. Technical Explanation

In a conventional SSRF vulnerability, the server's response may expose the contents returned by an internal service. In a blind SSRF scenario, the application does not reveal that response directly.

Out-of-band detection provides an alternative evidence channel:

- **DNS interaction:** The target server or a related resolver performs a lookup for the unique domain.
- **HTTP interaction:** The target server connects to the unique address and sends an HTTP request.
- **Correlation:** A unique address helps associate the observed interaction with the specific test.

A DNS interaction alone does not always prove that the application itself initiated an HTTP request. DNS caching, intermediary resolvers, and other infrastructure may affect the evidence. The interaction type and timing should therefore be examined carefully.

# 6. Security Impact

Depending on the target environment and the server's capabilities, blind SSRF may allow an attacker to:

- Trigger requests to internal systems without receiving their responses.
- Reach services that are not directly accessible from the internet.
- Cause server-side interactions with external systems.
- Potentially exploit internal services through request side effects.

The impact depends on accessible destinations, available protocols, and the actions those destinations perform.

# 7. Remediation

- Avoid fetching arbitrary URLs supplied by users.
- Use a strict allowlist for permitted outbound destinations.

- Validate resolved IP addresses and block restricted network ranges.
- Disable unnecessary outbound protocols and restrict egress traffic.
- Revalidate destinations after redirects.
- Monitor outbound DNS and HTTP activity for unexpected destinations.
- Apply least privilege and isolate services that need external network access.

# 8. Conclusion

This lab demonstrates how out-of-band testing can identify SSRF even when the application does not return the server-side response. Burp Suite Collaborator provides useful evidence of external interactions, helping testers detect and investigate blind SSRF vulnerabilities.

**Reference:** PortSwigger Web Security Academy — Blind SSRF

https://portswigger.net/web-security/ssrf/blind